CONFIDENTIAL

Vulnerability Assessment & Penetration Testing

Web Application Security Assessment Report

Client: abhishekzaveri.com

Target: https://abhishekzaveri.com

Report date: 03 October 2026

Version: 1.0 (Final)

This document contains confidential information intended solely for the named client. Do not distribute without authorisation.

Document Control

Document title	Vulnerability Assessment and Penetration Testing (VAPT) Report
Primary target	https://abhishekzaveri.com (WordPress website)
Additional hosts observed	www.devarsons.com, img1.wsimg.com, www.google.com, www.gstatic.com
Assessment type	Black-box web application security assessment (external, unauthenticated)
Assessment date	03 October 2026
Report version	1.0 - Final
Classification	Confidential

Table of Contents

Document Control 2

Table of Contents 2

1. Executive Summary 3

2. Scope and Methodology 4

3. Summary of Findings 6

4. Detailed Findings 8

5. Informational Observations 17

6. Remediation Roadmap 18

Appendix A - References 19

Appendix B - Disclaimer 19

1. Executive Summary

A security assessment of the public website **abhishekzaveri.com** was performed on 03 October 2026 to identify weaknesses that an external attacker could exploit. The test was black-box: no credentials or internal knowledge were used. Several additional hosts that the site and the test session interacted with (see Section 2) were also observed, and their findings are reported with the affected host stated.

Overall result. No Critical or High severity vulnerabilities were identified. The assessment produced **21 distinct findings** (125 occurrences): **6 Medium**, **7 Low** and **8 Informational**. The most significant items specific to abhishekzaveri.com are an **outdated jQuery 1.12.4** with known CVEs and an **end-of-life PHP 7.4.33** runtime disclosed in a response header. The remaining findings are largely missing HTTP security headers and transport-hardening gaps.

Number of occurrences by severity (total: 125)

Key observations

- **Outdated software:** jQuery 1.12.4 (known XSS and prototype-pollution CVEs) and PHP 7.4.33 (end-of-life since November 2022) are in use (VAPT-01, VAPT-07). Updating WordPress core, the theme and plugins is the highest-value action.
- **Browser-side protections are absent:** no Content-Security-Policy, anti-clickjacking or X-Content-Type-Options headers (VAPT-02, 03, 10).
- **Transport security is incomplete:** HSTS is not enabled and some content is reachable over plain HTTP (VAPT-08, 09).
- **Third-party dependencies:** external scripts are loaded without Subresource Integrity, and one asset host returns a wildcard CORS policy (VAPT-04, 05, 11).
- **Positive points:** the sites are served over HTTPS, and no SQL injection, authentication bypass or sensitive data exposure was identified by the tests performed. Several automated results (VAPT-12, VAPT-13 and two informational items) were reviewed and assessed as probable false positives.

Recommendation in brief

Update WordPress, the theme and plugins and move to a supported PHP version; then add a small set of HTTP response headers and an HTTP-to-HTTPS redirect at the web server or CDN. A prioritised plan is provided in Section 6.

2. Scope and Methodology

2.1 Scope

Host	Description	Findings (Med / Low / Info)
https://abhishekzaveri.com	**Primary target** - WordPress website	2 / 2 / 3
https://www.devarsons.com http://www.devarsons.com	Additional website crawled in the same test session	3 / 5 / 5
https://img1.wsimg.com	Third-party asset host (observed only)	1 / 0 / 0
www.google.com, www.gstatic.com	Third-party resources (e.g. reCAPTCHA); observed only, no findings	0 / 0 / 0

Counts show the findings the scanner attributed to each host. Findings that apply site-wide (such as missing security headers) are reported once per type with the total number of occurrences across all hosts. Only GET and form-submission requests were issued. No denial-of-service, social-engineering or physical tests were performed.

2.2 Methodology

The assessment followed an approach aligned with the **OWASP Web Security Testing Guide (WSTG)** and the **OWASP Top 10**:

Phase	Activity
1. Reconnaissance	Identification of hosts, technology stack (WordPress, PHP, CDN) and publicly exposed files.
2. Crawling and mapping	Spidering to enumerate pages, scripts, forms and external dependencies.
3. Passive analysis	Inspection of observed requests and responses for missing headers, outdated components and information disclosure.
4. Active testing	Automated active checks, including HTTP/HTTPS parity and User-Agent variation.
5. Analysis and rating	Triage, removal of duplicates, false-positive review, risk rating and remediation guidance.

2.3 Tooling and limitations

Testing used an industry-standard automated dynamic application security scanner in passive and active modes, followed by consolidation and review. Please note:

- The assessment is a point-in-time view and does not replace manual penetration testing.
- A high share of requests failed or timed out during the scan (about 72% network failures were recorded), so coverage of the target may be incomplete and further findings cannot be ruled out.
- No authenticated testing was done; the WordPress administration area, plugins' authenticated functions and business logic were not assessed.
- Third-party hosts were observed but not attacked; their findings must be addressed with the respective provider.
- Low-confidence automated results are flagged and, where assessed as likely false positives, labelled accordingly.

2.4 Risk rating model

Rating	Definition	Suggested remediation window
Critical / High	Directly exploitable with severe impact on confidentiality, integrity or availability.	Immediately / within 7 days
Medium	Weakness that reduces defence-in-depth or can be exploited under specific conditions.	Within 30 days
Low	Minor weakness or hardening gap with limited impact on its own.	Within 60-90 days
Informational	No direct security impact; observation or context for the reviewer.	As part of routine maintenance

3. Summary of Findings

ID	Finding	Severity	Confidence	Occurrences
VAPT-01	Vulnerable JavaScript Library (jQuery 1.12.4)	**Medium**	Medium	1
VAPT-02	Content Security Policy (CSP) Header Not Set	**Medium**	High	9
VAPT-03	Missing Anti-clickjacking Header	**Medium**	Medium	7
VAPT-04	Sub Resource Integrity (SRI) Attribute Missing	**Medium**	High	7
VAPT-05	Cross-Domain Misconfiguration (Permissive CORS Policy)	**Medium**	Medium	3
VAPT-06	Absence of Anti-CSRF Tokens	**Medium**	Low	2
VAPT-07	Server Leaks Version via "X-Powered-By" Header (PHP 7.4.33)	**Low**	Medium	5
VAPT-08	Strict-Transport-Security (HSTS) Header Not Set	**Low**	High	13
VAPT-09	HTTPS Content Available via HTTP	**Low**	Medium	5
VAPT-10	X-Content-Type-Options Header Missing	**Low**	Medium	11
VAPT-11	Cross-Domain JavaScript Source File Inclusion	**Low**	Medium	7
VAPT-12	Timestamp Disclosure - Unix	**Low**	Low	6
VAPT-13	Debug / Error Message Pattern in Response	**Low**	Medium	1
INFO-01	User Controllable HTML Element Attribute (Potential XSS)	**Info**	Low	8
INFO-02	Information Disclosure - Sensitive Information in URL	**Info**	Medium	1
INFO-03	Charset Mismatch	**Info**	Low	1
INFO-04	Information Disclosure - Suspicious Comments	**Info**	Medium	8
INFO-05	Modern Web Application	**Info**	Medium	7
INFO-06	Re-examine Cache-control Directives	**Info**	Low	8
INFO-07	Retrieved from Cache	**Info**	Medium	10
INFO-08	User Agent Fuzzer	**Info**	Medium	5

Occurrences indicate the number of individual requests/pages on which the issue was observed (all hosts).

Standards mapping

Finding	CWE	OWASP Top 10 category
VAPT-01 Vulnerable JavaScript Library (jQuery 1.12.4)	CWE-1395	A06:2021 Vulnerable and Outdated Components
VAPT-02 Content Security Policy (CSP) Header Not Set	CWE-693	A05:2021 Security Misconfiguration
VAPT-03 Missing Anti-clickjacking Header	CWE-1021	A05:2021 Security Misconfiguration
VAPT-04 Sub Resource Integrity (SRI) Attribute Missing	CWE-345	A05:2021 Security Misconfiguration
VAPT-05 Cross-Domain Misconfiguration (Permissive CORS Policy)	CWE-264	A01:2021 Broken Access Control
VAPT-06 Absence of Anti-CSRF Tokens	CWE-352	A01:2021 Broken Access Control
VAPT-07 Server Leaks Version via "X-Powered-By" Header (PHP 7.4.33)	CWE-497	A05:2021 Security Misconfiguration
VAPT-08 Strict-Transport-Security (HSTS) Header Not Set	CWE-319	A05:2021 Security Misconfiguration
VAPT-09 HTTPS Content Available via HTTP	CWE-311	A02:2021 Cryptographic Failures
VAPT-10 X-Content-Type-Options Header Missing	CWE-693	A05:2021 Security Misconfiguration
VAPT-11 Cross-Domain JavaScript Source File Inclusion	CWE-829	A08:2021 Software and Data Integrity Failures
VAPT-12 Timestamp Disclosure - Unix	CWE-497	A01:2021 Broken Access Control
VAPT-13 Debug / Error Message Pattern in Response	CWE-1295	A05:2021 Security Misconfiguration

4. Detailed Findings

Findings are ordered by severity. Each entry contains a description, supporting evidence, impact and recommended remediation. Where several occurrences exist, one representative URL is shown.

VAPT-01	Vulnerable JavaScript Library (jQuery 1.12.4)				MEDIUM
Severity	Medium	**Confidence**	Medium	**Occurrences**	1
CWE	CWE-1395	**OWASP**	A06:2021 Vulnerable and Outdated Components		
Host	abhishekzaveri.com				

Affected URL(s)

`https://abhishekzaveri.com/wp-includes/js/jquery/jquery.js?ver=1.12.4-wp`

Description

The site loads **jQuery 1.12.4**, a legacy release with several publicly known vulnerabilities: CVE-2020-11022 and CVE-2020-11023 (cross-site scripting via HTML handling in `htmlPrefilter`), CVE-2015-9251 (XSS through cross-domain Ajax requests) and CVE-2019-11358 (prototype pollution in `$.extend`).

Evidence

```
/*! jQuery v1.12.4
```

Impact

If application code passes untrusted data to the affected jQuery functions, an attacker could execute script in a visitor's browser. Exploitability depends on how the theme and plugins use jQuery, but running an end-of-life library is a recognised weakness in itself. The "1.12.4-wp" version string also suggests either an outdated WordPress core or a theme/plugin that forces the legacy jQuery build.

Recommendation

- Update WordPress core, the active theme and all plugins to their latest versions; current WordPress ships a patched jQuery 3.x.
- Check whether any theme or plugin dequeues the bundled jQuery and registers 1.12.4 manually; remove or replace that component.
- Re-test after the update to confirm that the old library is no longer served.

References

https://owasp.org/Top10/2021/A06_2021-Vulnerable_and_Outdated_Components/
https://nvd.nist.gov/vuln/detail/CVE-2019-11358
https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/

VAPT-02	Content Security Policy (CSP) Header Not Set				MEDIUM
Severity	Medium	**Confidence**	High	**Occurrences**	9
CWE	CWE-693	**OWASP**	A05:2021 Security Misconfiguration		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/sitemap.xml`
Representative example; observed 9 time(s) in total.

Description

The web servers do not send a **Content-Security-Policy** response header. CSP is a browser-enforced control that restricts which sources of scripts, styles, frames, images and other content a page may load.

Evidence

```
No Content-Security-Policy header present in the response headers.
```

Impact

If a cross-site scripting or content-injection flaw exists (for example through an outdated library such as VAPT-01), the absence of CSP removes a key layer of defence and makes data theft, defacement or malware distribution easier.

Recommendation

- Define and deploy a Content-Security-Policy header on all HTML responses, starting in report-only mode.
- Allow only the origins actually required (own domain, reCAPTCHA and other trusted third-party hosts) and avoid `unsafe-inline` / `unsafe-eval` where possible.
- On WordPress, headers can be set at the web server / CDN, or via a reputable security-headers plugin.

Example configuration:

```
Content-Security-Policy-Report-Only: default-src 'self';
  script-src 'self' https://www.google.com https://www.gstatic.com;
  frame-src https://www.google.com; img-src 'self' data:;
  frame-ancestors 'self'; base-uri 'self'; object-src 'none'
```

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

VAPT-03	Missing Anti-clickjacking Header				MEDIUM
Severity	Medium	**Confidence**	Medium	**Occurrences**	7
CWE	CWE-1021	**OWASP**	A05:2021 Security Misconfiguration		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/`
Representative example; observed 7 time(s) in total.

Description

Responses protect against neither "clickjacking" nor UI-redress attacks. Neither an **X-Frame-Options** header nor a CSP **frame-ancestors** directive is returned, so other sites can embed the pages in a frame.

Evidence

```
Header checked: x-frame-options - not present in the response.
```

Impact

An attacker can overlay the site in a hidden frame and trick visitors into clicking on elements they cannot see. The risk is higher for pages containing forms (such as the contact form) or any administrative interface.

Recommendation

- Send `X-Frame-Options: SAMEORIGIN` (or `DENY`) on all pages.
- Preferably also set CSP `frame-ancestors 'self'`.

Example configuration:

```
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self'
```

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

VAPT-04	Sub Resource Integrity (SRI) Attribute Missing				MEDIUM
Severity	Medium	**Confidence**	High	**Occurrences**	7
CWE	CWE-345	**OWASP**	A05:2021 Security Misconfiguration		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/`
Representative example; observed 7 time(s) in total.

Description

Pages load JavaScript or CSS from external domains without an **integrity** attribute. Subresource Integrity lets the browser verify that a fetched file has not been altered.

Evidence

```
<script src='https://img1.wsimg.com/traffic-assets/js/tccl.min.js'></script>
```

Impact

If an external host is compromised, or the file is altered at a CDN, malicious code would run with full access to the page without any warning (supply-chain attack).

Recommendation

- Add `integrity="sha384-..."` and `crossorigin="anonymous"` to external scripts and stylesheets where the files are static.
- Where the third-party file changes frequently, self-host a pinned copy.

Example configuration:

```
<script src="https://cdn.example.com/lib.min.js"
        integrity="sha384-<base64-hash>" crossorigin="anonymous"></script>
```

References

https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

VAPT-05	Cross-Domain Misconfiguration (Permissive CORS Policy)				MEDIUM
Severity	Medium	**Confidence**	Medium	**Occurrences**	3
CWE	CWE-264	**OWASP**	A01:2021 Broken Access Control		
Host	img1.wsimg.com (third party)				

Affected URL(s)

`https://img1.wsimg.com/traffic-assets/js/tccl.min.js`
Representative example; observed 3 time(s) in total.

Description

A resource loaded by the websites is served with **Access-Control-Allow-Origin: ***, allowing any origin to read the response through the browser. The affected host is a third-party asset domain, not the main application server.

Evidence

```
Access-Control-Allow-Origin: *
```

Impact

For public static JavaScript this is low-risk in practice. The same setting on an endpoint exposing non-public data would be a data-exposure issue, so the resource should be validated.

Recommendation

- Confirm the resource contains only public content.
- If the host is under your control, replace the wildcard with an explicit list of trusted origins or remove CORS headers.
- If it belongs to a third-party provider, record it as an accepted/transferred risk.

Example configuration:

```
Access-Control-Allow-Origin: https://abhishekzaveri.com
```

References

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

VAPT-06	Absence of Anti-CSRF Tokens				MEDIUM
Severity	Medium	**Confidence**	Low	**Occurrences**	2
CWE	CWE-352	**OWASP**	A01:2021 Broken Access Control		
Host	abhishekzaveri.com				

Affected URL(s)

`https://abhishekzaveri.com/contact/`
Representative example; observed 2 time(s) in total.

Description

A HTML form on the contact page (a Contact Form 7 form) was submitted without any recognised anti-CSRF token field. Cross-site request forgery forces a victim's browser to send a request without their knowledge.

Evidence

```
<form action="/contact/#wpcf7-f43-p28-o1" method="post" class="wpcf7-form" novalidate="novalidate">
```

Impact

For a public contact form that performs no authenticated action, the practical impact is low (an attacker could at most cause spam submissions on behalf of a visitor). It becomes relevant if the form is ever used to change data in a logged-in context. Confidence is Low because the form includes reCAPTCHA and other plugin-specific hidden fields that the scanner does not recognise as tokens.

Recommendation

- Keep the contact-form plugin and WordPress core up to date.
- Ensure bot protection (reCAPTCHA or equivalent) and rate limiting are active on the form.
- Use nonce-protected forms for any action that changes state for authenticated users.

References

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

VAPT-07	Server Leaks Version via "X-Powered-By" Header (PHP 7.4.33)				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	5
CWE	CWE-497	**OWASP**	A05:2021 Security Misconfiguration		
Host	abhishekzaveri.com				

Affected URL(s)

`https://abhishekzaveri.com/`

Representative example; observed 5 time(s) in total.

Description

The server discloses the underlying technology and exact version in the **X-Powered-By** response header.

Evidence

```
X-Powered-By: PHP/7.4.33
```

Impact

Version disclosure helps attackers select exploits. In addition, **PHP 7.4 reached end-of-life in November 2022** and no longer receives security fixes, so the underlying runtime itself is a risk regardless of the header.

Recommendation

- Upgrade to a currently supported PHP version (for example 8.2 or later) after compatibility testing of the theme and plugins.
- Suppress the header: set `expose_php = Off` in php.ini and remove X-Powered-By at the web server or CDN.

Example configuration:

```
; php.ini
expose_php = Off

# Apache
Header always unset X-Powered-By
```

References

https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
https://www.php.net/supported-versions.php

VAPT-08	Strict-Transport-Security (HSTS) Header Not Set				LOW
Severity	Low	**Confidence**	High	**Occurrences**	13
CWE	CWE-319	**OWASP**	A05:2021 Security Misconfiguration		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/robots.txt`
Representative example; observed 13 time(s) in total.

Description

HTTPS responses do not include the **Strict-Transport-Security** header, so browsers are not told to use HTTPS exclusively for the domain.

Evidence

```
No Strict-Transport-Security header in the response.
```

Impact

Visitors who first type the plain-HTTP address, or follow an old http:// link, can be downgraded or intercepted on hostile networks (SSL stripping) before the redirect to HTTPS.

Recommendation

- Enable HSTS with a max-age of at least one year once HTTPS works on all subdomains.
- Consider `includeSubDomains` and, when ready, HSTS preloading.

Example configuration:

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

References

https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
https://datatracker.ietf.org/doc/html/rfc6797

VAPT-09	HTTPS Content Available via HTTP				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	5
CWE	CWE-311	**OWASP**	A02:2021 Cryptographic Failures		
Host	www.devarsons.com				

Affected URL(s)

`http://www.devarsons.com/assets/css/main.min.css`
Representative example; observed 5 time(s) in total.

Description

Resources normally delivered over HTTPS can also be fetched over unencrypted HTTP, and are served instead of being redirected.

Evidence

```
http://www.devarsons.com/assets/css/main.min.css returned content over plain HTTP.
```

Impact

Content served over HTTP can be read or modified in transit. Altered CSS or JavaScript could be used to inject malicious content into pages.

Recommendation

- Configure a permanent (301) redirect from HTTP to HTTPS for all paths on every hostname.
- Combine with HSTS (VAPT-08).
- In Cloudflare or similar CDNs, enable "Always Use HTTPS".

Example configuration:

```
server {
    listen 80;
    server_name example.com www.example.com;
    return 301 https://$host$request_uri;
}
```

References

https://owasp.org/www-community/Security_Headers

VAPT-10	X-Content-Type-Options Header Missing				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	11
CWE	CWE-693	**OWASP**	A05:2021 Security Misconfiguration		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/robots.txt`
Representative example; observed 11 time(s) in total.

Description

Responses do not include **X-Content-Type-Options: nosniff**, so some browsers may guess the content type instead of trusting the declared Content-Type.

Evidence

```
Header checked: x-content-type-options - not present.
```

Impact

MIME-sniffing can cause a browser to interpret a file as a different type (for example, treating text as script), which can enable content-injection attacks.

Recommendation

- Add `X-Content-Type-Options: nosniff` to all responses.
- Ensure every response carries an accurate Content-Type header.

Example configuration:

```
X-Content-Type-Options: nosniff
```

References

https://owasp.org/www-community/Security_Headers

VAPT-11	Cross-Domain JavaScript Source File Inclusion				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	7
CWE	CWE-829	**OWASP**	A08:2021 Software and Data Integrity Failures		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/`
Representative example; observed 7 time(s) in total.

Description

Pages include JavaScript from third-party domains (for example img1.wsimg.com, and Google reCAPTCHA resources on the contact page). Such code runs with the same privileges as the site's own code.

Evidence

```
<script src='https://img1.wsimg.com/traffic-assets/js/tccl.min.js'></script>
```

Impact

The security of the site depends on the security of each external provider; a compromise at a provider would affect all visitors.

Recommendation

- Keep third-party scripts to the minimum needed and load them only from trusted providers.
- Apply SRI (VAPT-04) where possible and restrict allowed script sources through CSP (VAPT-02).

VAPT-12	Timestamp Disclosure - Unix				LOW
Severity	Low	**Confidence**	Low	**Occurrences**	6
CWE	CWE-497	**OWASP**	A01:2021 Broken Access Control		
Host	Multiple hosts				

Affected URL(s)

`https://www.devarsons.com/assets/vendor/gsap/chroma.min.js`
Representative example; observed 6 time(s) in total.

Description

Values resembling Unix timestamps were found in response bodies.

Evidence

```
2104542553 (evaluates to 2036-09-09 08:39:13)
```

Impact

Very low. The sampled value sits in a minified third-party library (chroma.min.js) and is most likely a numeric constant, not server-generated data. Considered a probable false positive.

Recommendation

- Manually confirm the values are not sensitive; no action is normally required for library constants.

References

https://cwe.mitre.org/data/definitions/200.html

VAPT-13	Debug / Error Message Pattern in Response				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	1
CWE	CWE-1295	**OWASP**	A05:2021 Security Misconfiguration		
Host	abhishekzaveri.com				

Affected URL(s)

`https://abhishekzaveri.com/wp-content/themes/betheme/css/layout.css?ver=20.9.6.2`

Description

A response matched a pattern normally associated with platform error pages (the phrase "Under Construction").

Evidence

```
Under Construction
```

Impact

Likely a **false positive**: the match occurred inside a theme stylesheet (layout.css) where the phrase is a CSS class or comment, not an error message. No stack traces or debug output were observed.

Recommendation

- No action required beyond confirming that WP_DEBUG is disabled in production (`define('WP_DEBUG', false);`).

5. Informational Observations

The items below carry no direct security impact, or were assessed as false positives, and are recorded for completeness.

ID	Observation	Details	Suggested action
INFO-01	**User Controllable HTML Element Attribute (Potential XSS)** (8 occurrences)	Contact-form field `_wpcf7_unit_tag` is reflected into an HTML id attribute on /contact/. This is the normal behaviour of Contact Form 7 and the value is generated by the plugin; manual testing would be needed to confirm there is no exploitable injection.	Keep the plugin updated; ensure output encoding is applied to reflected values.
INFO-02	**Information Disclosure - Sensitive Information in URL** (1 occurrences)	A request parameter (`r=0.4209...`) on a Wordfence-generated URL was flagged as a possible card number. The value is a random decimal used by the security plugin, so this is a **false positive**.	No action required.
INFO-03	**Charset Mismatch** (1 occurrences)	The oEmbed XML endpoint (/wp-json/oembed/) declares UTF-8 in the HTTP header but no encoding in the XML body.	Declare UTF-8 consistently in both header and document where possible.
INFO-04	**Information Disclosure - Suspicious Comments** (8 occurrences)	HTML comments such as `<!-- nice select css -->` matched keyword patterns. Reviewed comments describe CSS/JS includes only and contain no credentials or internal details.	Strip developer comments from production builds as a hygiene measure.
INFO-05	**Modern Web Application** (7 occurrences)	Pages contain links without conventional href attributes, indicating script-driven navigation. Noted for test coverage; not a vulnerability.	No action. Use client-side aware testing for deeper manual review.
INFO-06	**Re-examine Cache-control Directives** (8 occurrences)	Some responses use `max-age=14400` or lack explicit cache directives. Acceptable for static assets.	Ensure dynamic or user-specific pages use no-store, and static assets use explicit public, max-age directives.
INFO-07	**Retrieved from Cache** (10 occurrences)	Static assets were served from a shared cache / CDN edge, which is expected behaviour behind a CDN.	Confirm that no personalised or sensitive content can be cached.
INFO-08	**User Agent Fuzzer** (5 occurrences)	Requests with a legacy browser User-Agent were compared against the baseline response to detect device- or crawler-specific behaviour. No notable differences reported.	Verify no hidden or alternate content is served to specific user agents.

Environment notes

- abhishekzaveri.com runs on **WordPress** with the Betheme theme (version 20.9.6.2 observed), Contact Form 7, reCAPTCHA and the Wordfence security plugin. The theme version is old and should be checked against the vendor's latest release.
- Responses reveal PHP/7.4.33 (see VAPT-07). The REST API (/wp-json/) is publicly reachable, which is default WordPress behaviour; user enumeration through it should be restricted if not needed.
- The websites are delivered through a CDN / reverse proxy, which provides a convenient central place to apply the security headers recommended here.

6. Remediation Roadmap

Priority	Action	Addresses	Effort	Target
1	Update WordPress core, Betheme theme and all plugins; remove any forced legacy jQuery	VAPT-01	Medium	30 days
2	Upgrade PHP to a supported version and hide X-Powered-By	VAPT-07	Medium	30 days
3	Redirect HTTP to HTTPS and enable HSTS	VAPT-08, 09	Low	30 days
4	Add X-Frame-Options / frame-ancestors and X-Content-Type-Options headers	VAPT-03, 10	Low	30 days
5	Roll out a Content-Security-Policy (report-only first)	VAPT-02	Medium	30-60 days
6	Add SRI or self-host external scripts; review third-party CORS and script use; confirm contact-form protections	VAPT-04, 05, 06, 11	Low-Medium	60 days
7	Confirm probable false positives; remove developer comments; review caching	VAPT-12, 13, INFO	Low	90 days

Consolidated header baseline

The following baseline can be applied at the web server or CDN and closes VAPT-03, 07, 08 and 10 in one change. Test in staging first, and deploy CSP in report-only mode before enforcing.

```
# Nginx (inside the HTTPS server block)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "SAMEORIGIN" always;
proxy_hide_header X-Powered-By;

# Apache (.htaccess or vhost)
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "SAMEORIGIN"
Header always unset X-Powered-By
```

Retest

After remediation, a retest is recommended to verify closure of all Medium and Low findings. Because coverage was affected by network failures, the retest should be run against a stable connection or an allow-listed source address.

7. Conclusion

No Critical or High risk vulnerabilities were identified. The main exposure of abhishekzaveri.com comes from outdated components (jQuery 1.12.4, PHP 7.4, an older theme version), which should be updated first. The remaining items are configuration-level hardening gaps that can be closed quickly. Together these measures would bring the sites in line with current best practice and substantially reduce exposure to client-side attacks.

Appendix A - References

- OWASP Top 10 - https://owasp.org/Top10/
- OWASP Web Security Testing Guide - https://owasp.org/www-project-web-security-testing-guide/
- OWASP Secure Headers Project - https://owasp.org/www-project-secure-headers/
- MDN Web Docs: HTTP security - https://developer.mozilla.org/en-US/docs/Web/Security
- WordPress Hardening - https://developer.wordpress.org/advanced-administration/security/hardening/
- MITRE CWE - https://cwe.mitre.org/
- PHP supported versions - https://www.php.net/supported-versions.php

Appendix B - Disclaimer

This report reflects the security status of the in-scope systems at the time of testing and is based on the methods described in Section 2. It does not guarantee that the systems are free of vulnerabilities. The report is confidential and intended solely for the owner of the assessed systems; disclosure to third parties without written consent is prohibited.